Cyber Assessment Framework (CAF) Mini Audit Report

Objective A – Managing Security Risk

Organisation: Midlands Health Digital Services Trust (Fictional Case Study)
Assessment Date: March 2026
Assessor: Patrick Adefowora

---

1. Executive Summary

This report presents the findings of a Cyber Assessment Framework (CAF) review conducted against **Objective A – Managing Security Risk**. The purpose of the assessment was to evaluate whether the organisation demonstrates effective governance, risk management processes, asset management practices, and supply chain risk oversight aligned with the Indicators of Good Practice defined by the National Cyber Security Centre.

The assessment found that the organisation has implemented foundational governance structures and risk management processes; however, several areas require improvement to ensure cyber security risk is effectively managed across critical services.

Key observations include:

- Cyber security governance exists, but board-level oversight of cyber risk reporting is inconsistent.
- Risk management processes are established but not regularly updated following operational changes.
- Asset inventory is incomplete and does not include all software dependencies or data classifications.
- Supplier security requirements exist in contractual agreements, but ongoing monitoring of supplier security posture is limited.

Overall maturity for **CAF Objective A** is assessed as:

Amber – Developing

The organisation demonstrates partial alignment with CAF expectations but requires improvements to governance reporting, risk review frequency, asset visibility, and supplier assurance monitoring.

2. Organisation Overview

Midlands Health Digital Services Trust provides digital infrastructure and IT services supporting a regional healthcare network of hospitals and clinics.

The organisation manages several critical systems, including:

- Electronic Patient Record (EPR) systems
- Clinical appointment and scheduling platforms
- Remote care and telemedicine systems
- Internal email and collaboration platforms

The organisation employs approximately **2,500 staff** and manages infrastructure supporting healthcare operations across multiple facilities.

Due to the critical nature of healthcare services, cyber resilience is essential to ensure the availability, integrity, and confidentiality of patient data and digital services.

3. Audit Scope

This assessment focused on **CAF Objective A – Managing Security Risk**, which evaluates whether an organisation effectively governs and manages cyber security risks affecting essential services.

The assessment reviewed the following principles:

- **A1 – Governance**
- **A2 – Risk Management**
- **A3 – Asset Management**
- **A4 – Supply Chain Risk Management**

The review examined governance documentation, risk management processes, and policy controls relevant to these areas.

4. Methodology

The assessment was conducted through a structured review of governance and risk management documentation against the Indicators of Good Practice defined in the Cyber Assessment Framework.

Evidence reviewed included:

- Information security policies
- Cyber risk registers

- Asset inventory records
- Supplier contract security clauses
- Security awareness documentation
- Governance and management reporting documentation

The assessment evaluated whether the organisation's processes align with CAF expectations for managing cyber security risk.

5. Assessment Findings

5.1 A1 – Governance

Observation

The organisation maintains an information security governance structure supported by an Information Security Policy and defined security roles. However, cyber risk reporting to executive leadership and board-level governance bodies occurs irregularly.

Evidence

- Information Security Policy reviewed
- Risk register maintained by IT security team
- Limited documentation of cyber risk reporting to board governance meetings

Risk

Inconsistent reporting of cyber security risks may limit senior leadership awareness of emerging threats and reduce the organisation's ability to allocate resources proportionate to risk exposure.

Rating

Amber – Developing

5.2 A2 – Risk Management

Observation

The organisation conducts cyber risk assessments and maintains a risk register. However, risk assessments are typically performed annually and are not consistently updated following major system changes or infrastructure updates.

Evidence

- Risk register last updated 12 months prior to assessment
- Documented risk assessment process exists, but lacks defined review intervals following operational changes

Risk

Infrequent risk reviews may result in newly introduced vulnerabilities remaining unidentified or unmanaged.

Rating

Amber – Developing

5.3 A3 – Asset Management

Observation

An IT asset inventory exists covering hardware assets such as servers, workstations, and network infrastructure. However, the asset inventory does not fully capture software dependencies, cloud services, or data classification levels.

Evidence

- Hardware asset inventory reviewed
- No centralised software dependency mapping
- Limited documentation of data classification levels

Risk

Incomplete asset visibility may reduce the organisation's ability to effectively protect critical systems and detect potential compromise.

Rating

Amber – Developing

5.4 A4 – Supply Chain Risk Management

Observation

Third-party service providers are required to meet contractual security requirements. However, ongoing supplier assurance monitoring is limited and there is no structured process for periodic supplier security assessments.

Evidence

- Security requirements included in supplier contracts
- No documented supplier security review schedule

Risk

Without ongoing assurance activities, supplier security posture may degrade over time, potentially exposing critical services to external cyber risks.

Rating

Amber – Developing

6. Risk Observations Summary

The following key cyber security risks were identified during the assessment:

1. **Governance oversight risk** due to inconsistent cyber risk reporting to senior leadership.
2. **Risk management maturity gaps** resulting from infrequent risk assessment updates.
3. **Limited asset visibility**, particularly relating to software dependencies and data classification.
4. **Supplier assurance weaknesses** due to limited monitoring of third-party security posture.

7. Recommendations

The following actions are recommended to improve alignment with CAF expectations:

1. Introduce **quarterly cyber risk reporting to executive leadership and governance boards**.
2. Implement **continuous risk register review procedures**, including updates following major system changes.

3. Expand the asset inventory to include **software dependencies, cloud services, and data classification levels**.
4. Establish a **supplier assurance monitoring programme**, including periodic supplier security assessments.

8. Maturity Assessment

Summarise ratings for each CAF principle.

CAF Principles	Rating
A1 Governance	Amber
A2 Risk Management	Amber
A3 Asset Management	Amber
A4 Supply Chain Risk	Amber

Overall maturity level:

Amber - Developing

9. Conclusion

The organisation demonstrates foundational governance and cyber risk management processes aligned with the Cyber Assessment Framework. However, improvements are required to ensure cyber security risks affecting critical healthcare services are consistently identified, monitored, and communicated to senior leadership.

Addressing the identified gaps in governance oversight, asset visibility, and supplier assurance will strengthen the organisation's overall cyber resilience posture.